

VULNERABILITY ASSESSMENT REPORT

Windows Server 2012 • Virtualized Lab Environment

Classification	Confidential
Target System	Windows Server 2012 R2 (192.168.163.136)
Assessment Type	Vulnerability Assessment (Internal Network)
Tools Used	Tenable Nessus Essentials • Zenmap (Nmap)
Assessment Date	March 2026

Prepared by:

Mamoon Ahmad

mamoonahmad.dev@gmail.com | www.github.com/maamooon | www.linkedin.com/in/maamooon

1. EXECUTIVE SUMMARY

This report presents the findings of a vulnerability assessment conducted on a Windows Server 2012 R2 system deployed within a virtualized lab environment. The objective was to identify security weaknesses that could be exploited by adversaries and to evaluate the overall security posture of the target system.

The assessment was executed using industry-standard tools—Tenable Nessus and Zenmap (Nmap) - scanning from a separate machine on the same virtual network segment to simulate a realistic attacker perspective. The target was intentionally configured with multiple insecure settings, including a disabled host firewall, legacy SSL/SMB protocols, self-signed weak-key certificates, and an unsupported operating system.

The scan revealed 17 findings across four severity tiers. The most critical issues were the use of obsolete SSL 2.0/3.0 protocols and an unsupported Windows OS version, both carrying CVSS scores of 9.8–10.0. Additional high and medium findings centred on weak cryptographic configurations affecting the FTP service, while SMB signing and ICMP timestamp disclosure rounded out the lower-severity items.

Key takeaways include the urgent need to migrate to a supported OS, enforce TLS 1.2+, replace all weak certificates, enable SMB signing, and maintain a routine patch-management cadence.



2. SCOPE & METHODOLOGY

2.1 Assessment Scope

Target IP	192.168.163.136
Operating System	Microsoft Windows Server 2012 R2 Standard
Network Segment	Internal virtual network (VMware Workstation)
Ports Assessed	All TCP/UDP (full port scan)
Services in Scope	FTP (21), SMB (445), RPC/DCE, IIS HTTPS, OS services

2.2 Methodology

The assessment followed a four-phase approach:

- Phase 1 – Environment Configuration: Target system deliberately configured with legacy protocols, disabled firewall, weak SSL certificate (512-bit RSA / SHA-1), SMBv1, IIS + FTP, and missing security patches.
- Phase 2 – Network Discovery: Zenmap (Nmap) intensive scan (-T4 -A -v) used to enumerate open ports, service banners, and OS fingerprinting.
- Phase 3 – Vulnerability Scanning: Tenable Nessus Essentials executed a credential less network scan against all discovered services, identifying CVEs and misconfigurations mapped to CVSS scoring.
- Phase 4 – Analysis & Reporting: Findings triaged by severity (Critical → Low), documented with impact descriptions, evidence screenshots, and actionable remediation guidance.

2.3 Tools & Versions

Tool	Version / Edition	Purpose
Tenable Nessus Essentials	10.x	Vulnerability scanning & CVE detection
Zenmap (Nmap)	7.x	Port scanning & service enumeration
VMware Workstation	Latest	Virtualization platform
Kali Linux	2025.3	Attacker / scanning machine OS

2.4 Environment Setup — Evidence

The following screenshots document the intentional misconfiguration of the target environment prior to scanning.

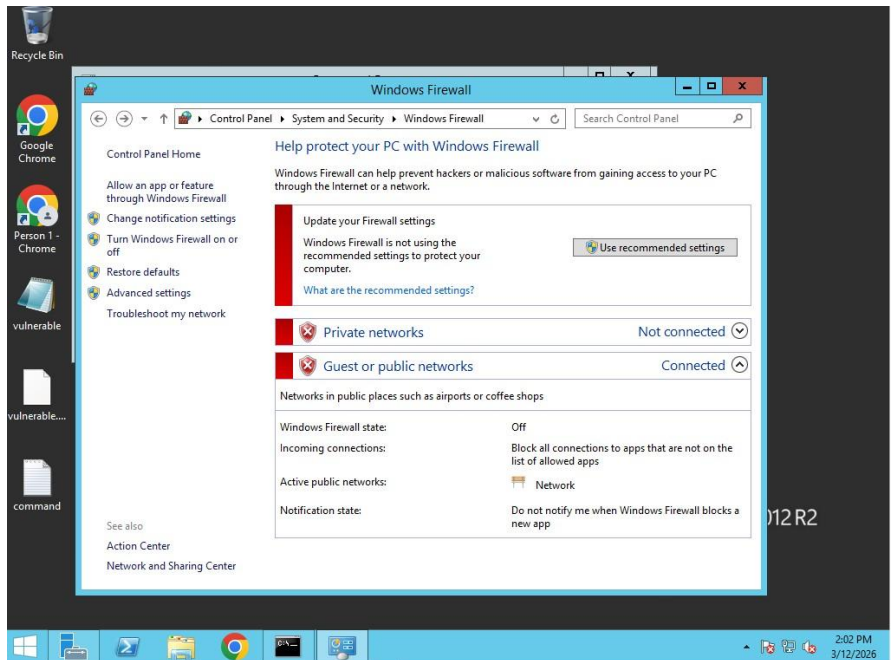


Figure 2 Windows Firewall disabled on target server

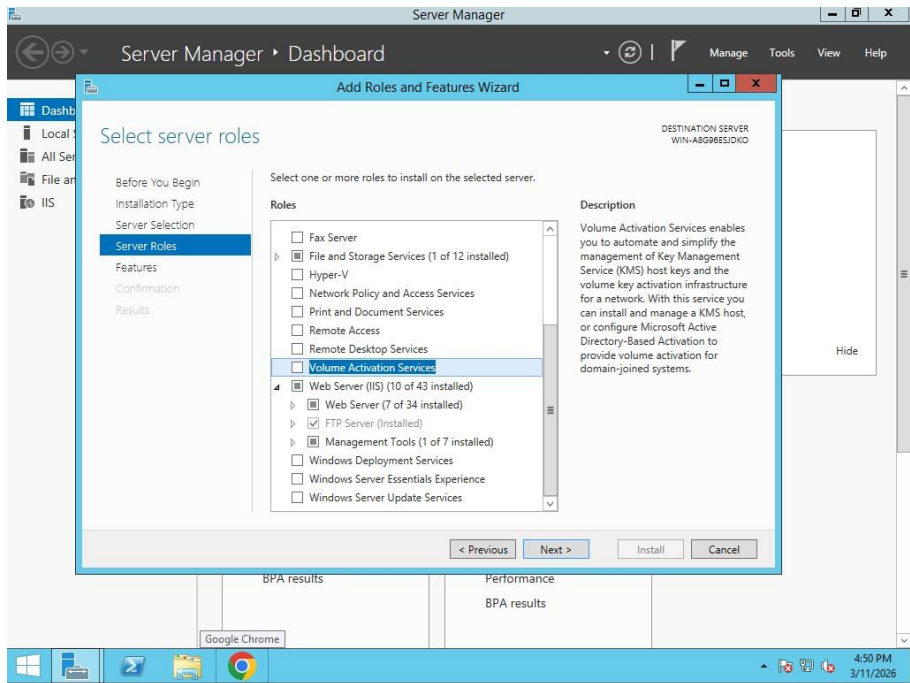


Figure 1 IIS WebServer with FTP installed

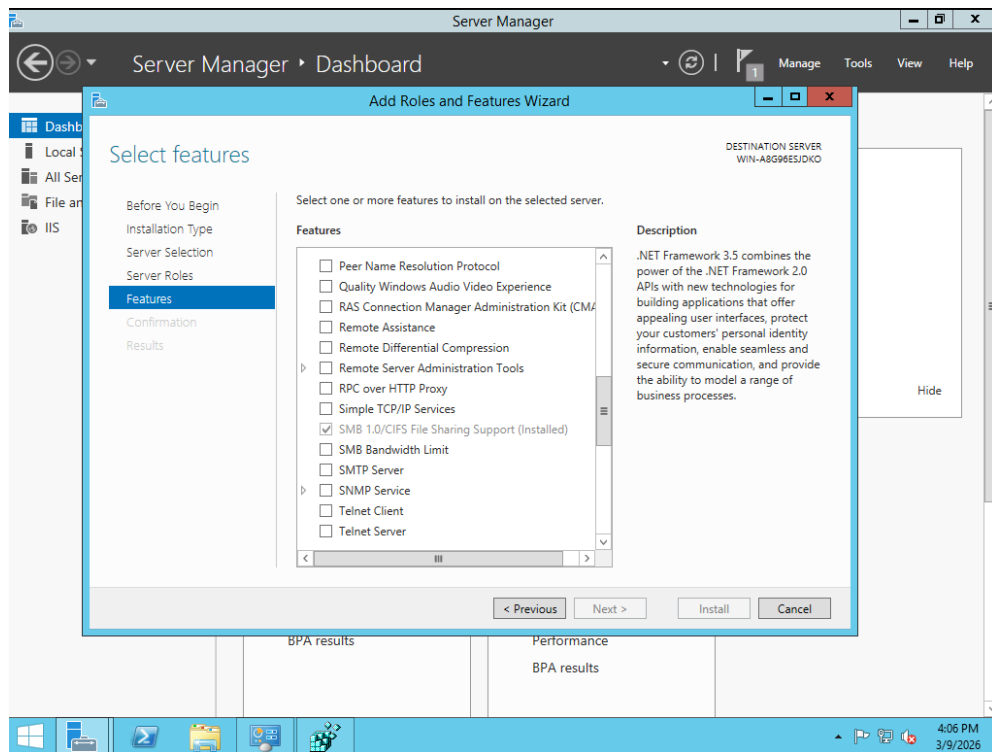


Figure 3 SMBv1 enabled via server features

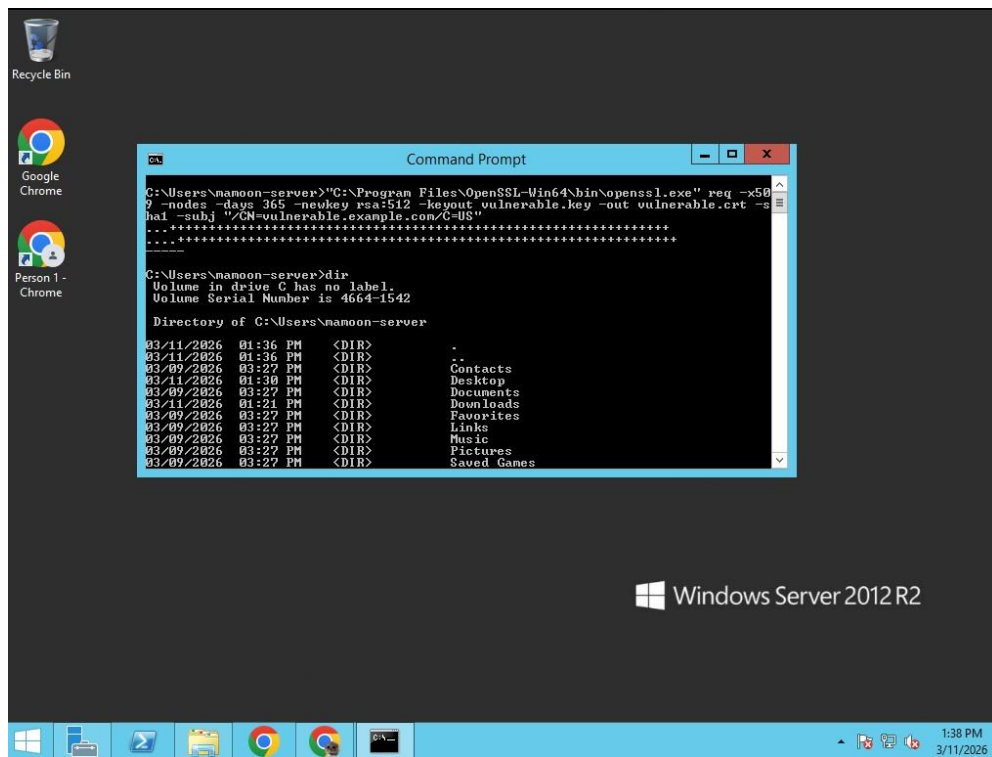


Figure 4 Weak SHA-1 SSL Certificate created via OpenSSL

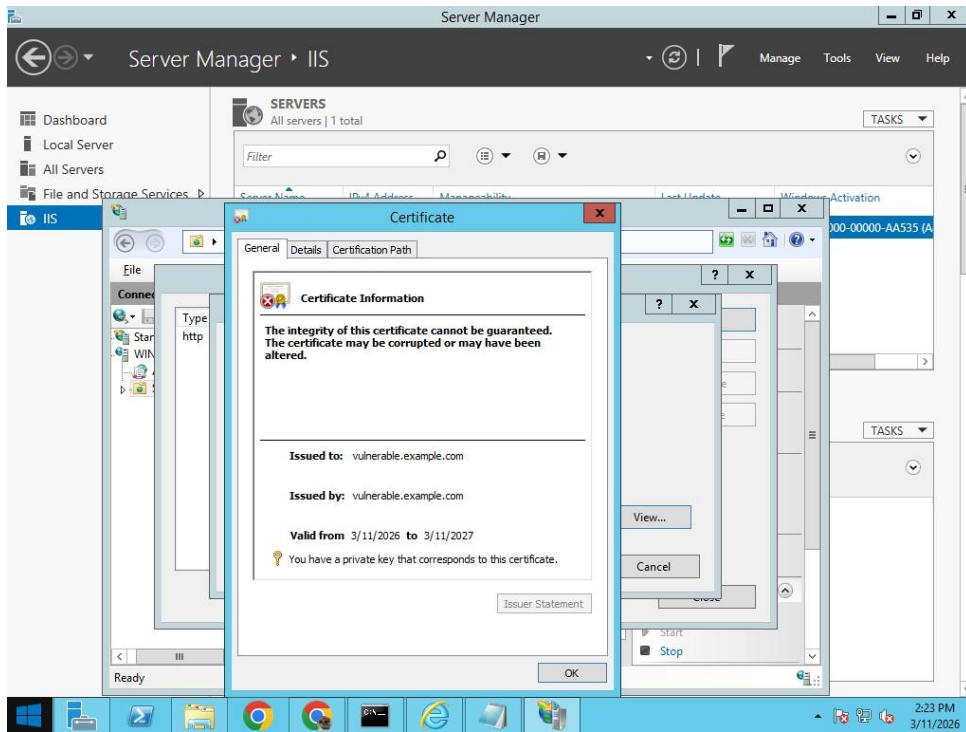


Figure 5 Vulnerable Weak SSL Certificate installed on IIS Server

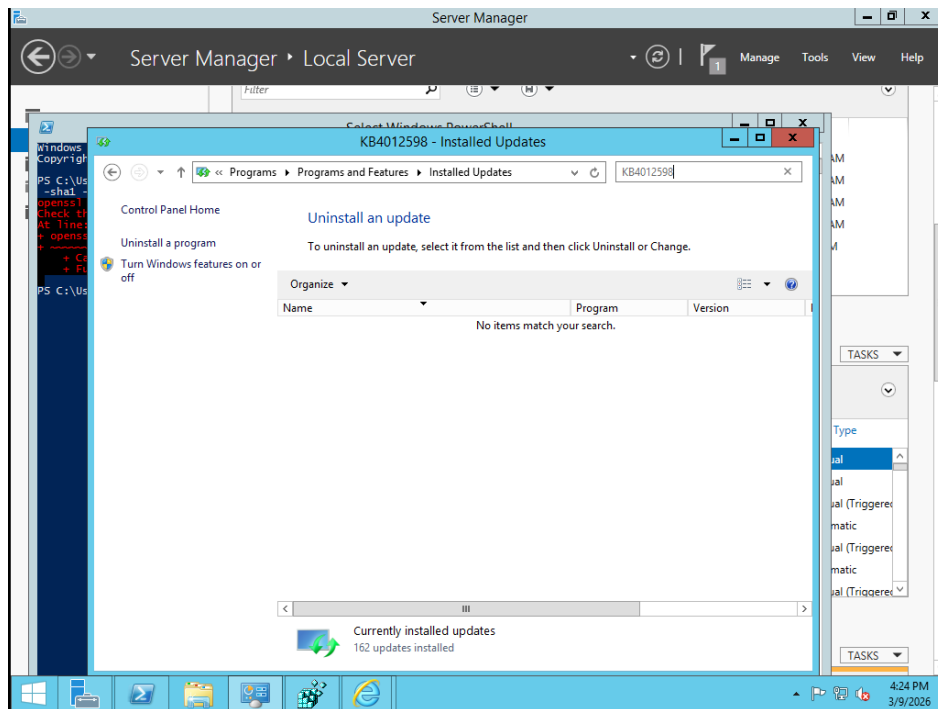


Figure 6 Missing Window Update KB4012598 (Eternal Blue Patch)

3. ASSESSMENT FINDINGS – OVERVIEW

3.1 Vulnerability Distribution

Service / Component	Critical	High	Medium	Low	Notes
SSL/TLS (FTP Port 21)	1	1	6	3	Primary attack surface
SMB / LSAD (Port 445)	0	0	1	0	Signing & elevation risks
Windows OS	1	0	0	0	Unsupported OS lifecycle
TLS Protocol Versions	0	0	2	0	TLS 1.0 & 1.1 deprecated
ICMP Timestamp	0	0	0	1	Information disclosure
TOTAL	2	1	10	4	17 findings total

3.2 Port Scanning & Network Discovery - Evidence

Zenmap (Nmap) and Nessus were used sequentially: Nmap for initial reconnaissance, Nessus for deep vulnerability analysis.

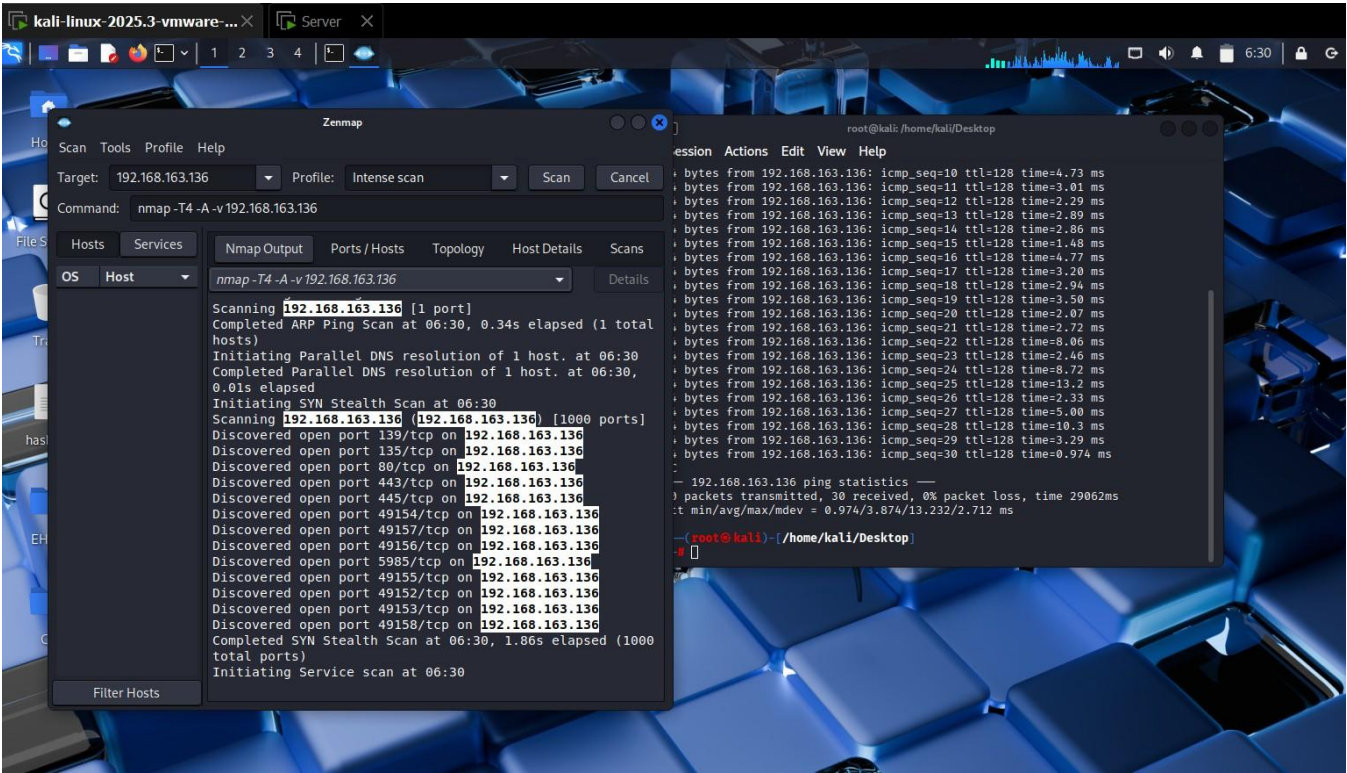


Figure 7 Zenmap (Nmap) scan output showing open ports

4. VULNERABILITIES SUMMARY

Critical Vulnerabilities

Vulnerability	Category	Severity	Affected Asset
Unsupported Windows OS	Windows	Critical	192.168.163.136
SSL v2.0 & v3.0 Protocol Detection	Service Detection	Critical	192.168.163.136

High Vulnerabilities

Vulnerability	Category	Severity	Affected Asset
SSL Medium Strength Cipher Suites Supported	General	High	192.168.163.136

Medium Vulnerabilities

Vulnerability	Category	Severity	Affected Asset
SMB Signing Not Required	Windows	Medium	192.168.163.136
Security Update for SAM and LSAD (MS16-047)	Windows	Medium	192.168.163.136
SSL Certificate Cannot Be Trusted	General	Medium	192.168.163.136
SSL Self-Signed Certificate	General	Medium	192.168.163.136
SSL RC4 Cipher Suites Supported	General	Medium	192.168.163.136
SSL Certificate with Wrong Hostname	General	Medium	192.168.163.136
SSL Certificate Contains Weak RSA Keys	General	Medium	192.168.163.136
TLS Version 1.0 Protocol Detection	Service Detection	Medium	192.168.163.136
TLS Version 1.1 Deprecated Protocol	Service Detection	Medium	192.168.163.136
SSL Certificate Signed Using Weak Hashing Algorithm	Misc.	Medium	192.168.163.136

Low Vulnerabilities

Vulnerability	Category	Severity	Affected Asset
ICMP Timestamp Request Remote Date Disclosure	Windows	Low	192.168.163.136
SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)	Misc.	Low	192.168.163.136

VULNERABILITY ASSESSMENT REPORT

Vulnerability	Category	Severity	Affected Asset
SSLv3 Padding Oracle (POODLE)	General	Low	192.168.163.136
SSL Certificate Chain Contains RSA Keys < 2048 Bits	General	Low	192.168.163.136

5. DETAILED FINDINGS

5.1 Critical Findings

5.1.1. Unsupported Windows Operating System **CRITICAL**

Host: 192.168.163.136 Port: N/A (OS-level) CVE/Reference: CVSS v3.0: 10.0 | Nessus Plugin 108797

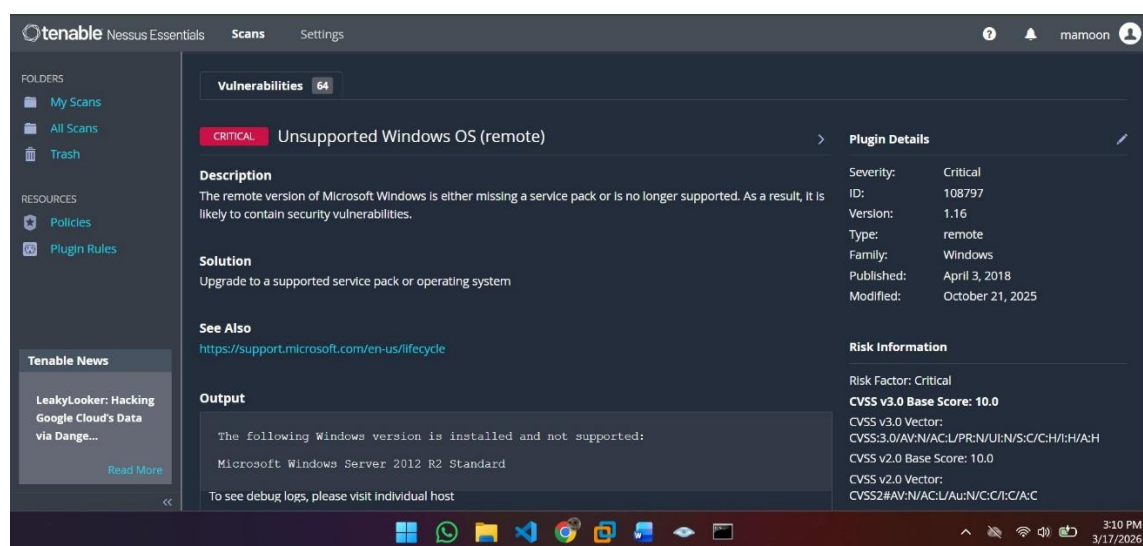
Impact

The installed Microsoft Windows Server 2012 R2 is no longer supported by Microsoft and does not receive security updates. Running an end-of-life OS exposes the system to all known and future unpatched vulnerabilities. Any exploit targeting unpatched CVEs can result in complete system compromise, data exfiltration, or ransomware deployment.

Recommended Solution

Migrate to a supported operating system (Windows Server 2022 or later). If immediate migration is not possible, apply Extended Security Updates (ESU) and isolate the system from public-facing networks until migration is complete.

Evidence



Nessus Plugin 108797 - Unsupported Windows OS (remote) flagged as Critical

5.1.2. SSL Version 2.0 and 3.0 Protocol Detection **CRITICAL**

Host: 192.168.163.136 Port: 21/tcp (FTP-SSL), 443/tcp CVE/Reference: CVSS v3.0: 9.8 | Nessus Plugin 20007

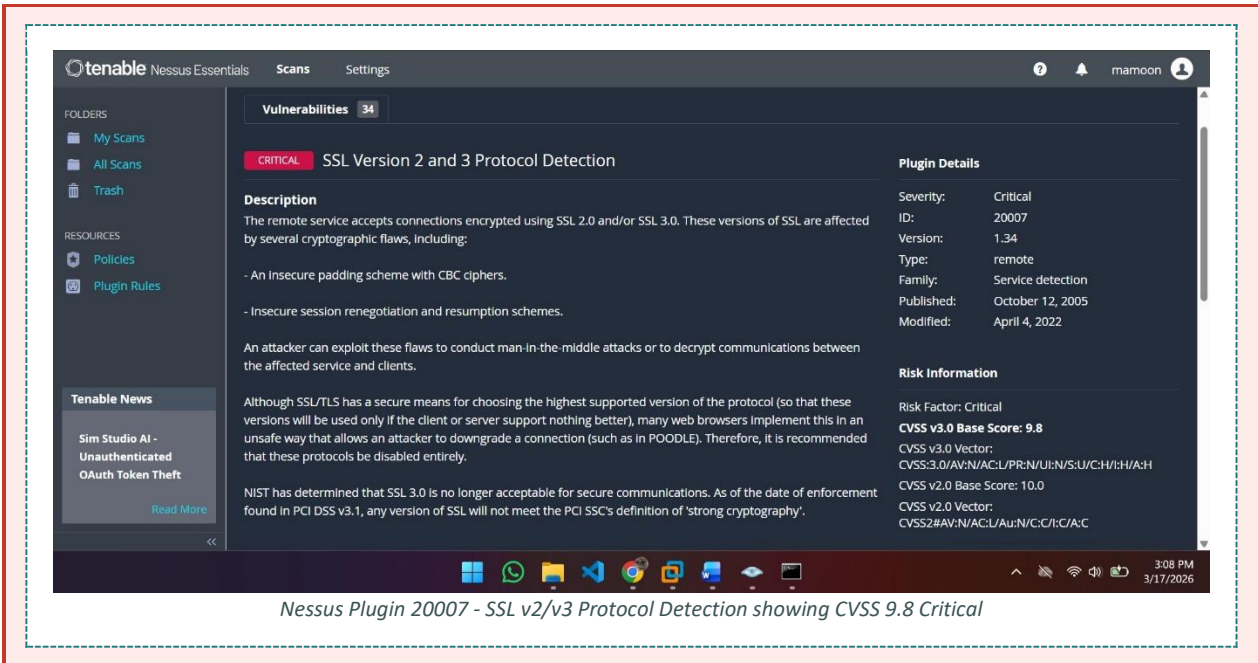
Impact

The remote service accepts connections encrypted using SSL 2.0 and/or SSL 3.0. These protocols contain multiple cryptographic flaws including insecure CBC-mode padding, weak cipher suites, and insecure session renegotiation. An attacker on the network path can conduct man-in-the-middle attacks or decrypt communications using known techniques such as POODLE.

Recommended Solution

Disable SSL 2.0 and SSL 3.0 at the application/server configuration level. Enable TLS 1.2 (minimum) with approved cipher suites, and preferably TLS 1.3. Update IIS and FTP SSL bindings accordingly.

Evidence



5.2 High Findings

5.2.1. SSL Medium Strength Cipher Suites Supported (SWEET32) HIGH

Host: 192.168.163.136 Port: 21/tcp (FTP-SSL) CVE/Reference: CVE-2016-2183 | CVSS v3.0: ~7.5 | Nessus Plugin 42873

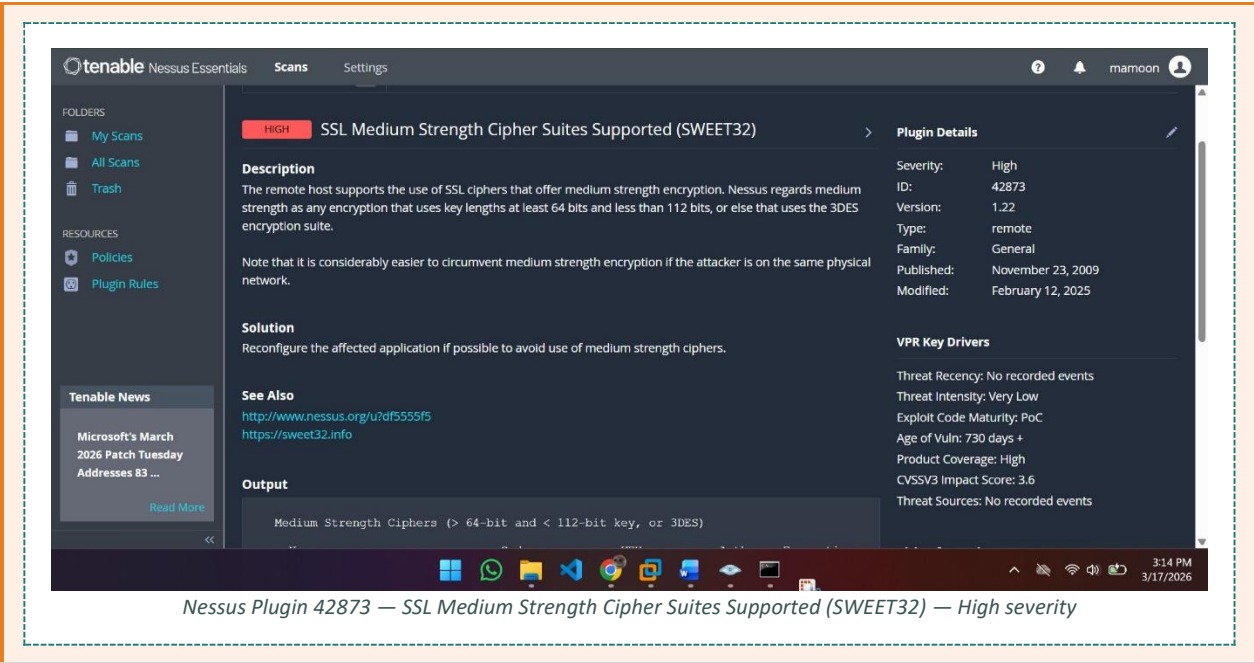
Impact

The FTP service supports SSL cipher suites using key lengths between 64 and 112 bits, including the 3DES (Triple-DES) cipher suite. The SWEET32 birthday attack allows an attacker with sustained access to network traffic (tens of millions of ciphertexts) to recover plaintext from encrypted sessions, including session cookies or credentials.

Recommended Solution

Reconfigure the server to disable medium-strength and 3DES cipher suites. Enforce only strong cipher suites: AES-128-GCM or AES-256-GCM with TLS 1.2+. Use the IIS Crypto tool or Windows group policy (SChannel registry keys) to enforce the cipher order.

Evidence



5.3 Selected Medium Findings

5.3.1. SMB Signing Not Required **MEDIUM**

Host: 192.168.163.136 Port: 445/tcp (SMB) CVE/Reference: CVSS v3.0: 5.3 | Nessus Plugin 57608

Impact

The SMB server does not enforce message signing, allowing an unauthenticated attacker on the local network to relay SMB authentication and conduct man-in-the-middle attacks. This can be chained with NTLM relay attacks (e.g., using Responder + ntlmrelayx) to achieve unauthorized access or privilege escalation.

Recommended Solution

Enable mandatory SMB signing via Group Policy: Computer Configuration → Windows Settings → Security Settings → Local Policies → Security Options → 'Microsoft network server: Digitally sign communications (always)' = Enabled.

Evidence

tenable Nessus Essentials Scans Settings mamoon

FOLDERS

- My Scans
- All Scans
- Trash

RESOURCES

- Policies
- Plugin Rules

Tenable News

Microsoft Azure Data Explorer Cross-Tenant Data Le...

Read More

MEDIUM SMB Signing not required

Description

Signing is not required on the remote SMB server. An unauthenticated, remote attacker can exploit this to conduct man-in-the-middle attacks against the SMB server.

Solution

Enforce message signing in the host's configuration. On Windows, this is found in the policy setting 'Microsoft network server: Digitally sign communications (always)'. On Samba, the setting is called 'server signing'. See the 'see also' links for further details.

See Also

<http://www.nessus.org/u?df39b8b3>
<http://technet.microsoft.com/en-us/library/cc731957.aspx>
<http://www.samba.org/samba/docs/current/man-html/smb.conf.5.html>
<https://www.nessus.org/u?74b80723>
<http://www.nessus.org/u?7a3cac4ea>

Output

No output recorded.

Plugin Details

Severity: Medium
 ID: 57608
 Version: 1.20
 Type: remote
 Family: Misc.
 Published: January 19, 2012
 Modified: October 5, 2022

Risk Information

Risk Factor: Medium
CVSS v3.0 Base Score: 5.3
 CVSS v3.0 Vector: CVSS:3.0/AV:N/ACL:PR:N/UI:N/S:U/C:N/I:L/A:N
 CVSS v3.0 Temporal Vector: CVSS:3.0/E:U/RL:O/RC:C
 CVSS v3.0 Temporal Score: 4.6
 CVSS v2.0 Base Score: 5.0
 CVSS v2.0 Temporal Score: 3.7
 CVSS v2.0 Vector: CVSS:2.0/AV:N/AC:L/AU:N/C:N/I:L/A:N

Nessus Plugin 57608 - SMB Signing Not Required on port 445

5.3.2. Security Update for SAM and LSAD Remote Protocols (MS16-047) MEDIUM

Host: 192.168.163.136 Port: 49158/tcp (DCE-RPC) CVE/Reference: CVE-2016-0128 | CVSS v3.0: 6.8 | Nessus Plugin 90510

Impact

The host is vulnerable to an elevation-of-privilege flaw in the SAM and LSAD protocols due to improper authentication-level negotiation over RPC. A man-in-the-middle attacker can force authentication downgrade to impersonate an authenticated user and gain access to the SAM database, enabling credential harvesting.

Recommended Solution

Apply Microsoft Security Bulletin MS16-047 (KB3148527). Ensure all cumulative Windows updates are current. Enforce strong RPC authentication via Group Policy to prevent downgrade attacks.

Evidence

tenable Nessus Essentials Scans Settings mamoon

FOLDERS

- My Scans
- All Scans
- Trash

RESOURCES

- Policies
- Plugin Rules

Tenable News

Microsoft's March 2026 Patch Tuesday Addresses 83 ...

Read More

Network Scan / Plugin #90510

[Back to Vulnerability Group](#)

Vulnerabilities 36

MEDIUM MS16-047: Security Update for SAM and LSAD Remote Protocols (...)

Description

The remote Windows host is affected by an elevation of privilege vulnerability in the Security Account Manager (SAM) and Local Security Authority (Domain Policy) (LSAD) protocols due to improper authentication level negotiation over Remote Procedure Call (RPC) channels. A man-in-the-middle attacker able to intercept communications between a client and a server hosting a SAM database can exploit this to force the authentication level to downgrade, allowing the attacker to impersonate an authenticated user and access the SAM database.

Solution

Microsoft has released a set of patches for Windows Vista, 2008, 7, 2008 R2, 2012, 8.1, RT 8.1, 2012 R2, and 10.

See Also

<http://www.nessus.org/u?52ade1e9>

Output

Plugin Details

Severity: Medium
 ID: 90510
 Version: 1.10
 Type: remote
 Family: Windows
 Published: April 13, 2016
 Modified: January 30, 2026

VPR Key Drivers

Threat Recency: No recorded events
 Threat Intensity: Very Low
 Exploit Code Maturity: Unproven
 Age of Vuln: 730 days +

Nessus Plugin 90510 - MS16-047 Security Update for SAM and LSAD Remote Protocols

5.3.3. SSL Certificate Issues (Self-Signed, Wrong Hostname, Weak Keys) MEDIUM

Host: 192.168.163.136 Port: 21/tcp (FTP-SSL) CVE/Reference: CVSS v3.0: 5.3–6.5 | Nessus Plugins 51192, 57582, 60108, 45411

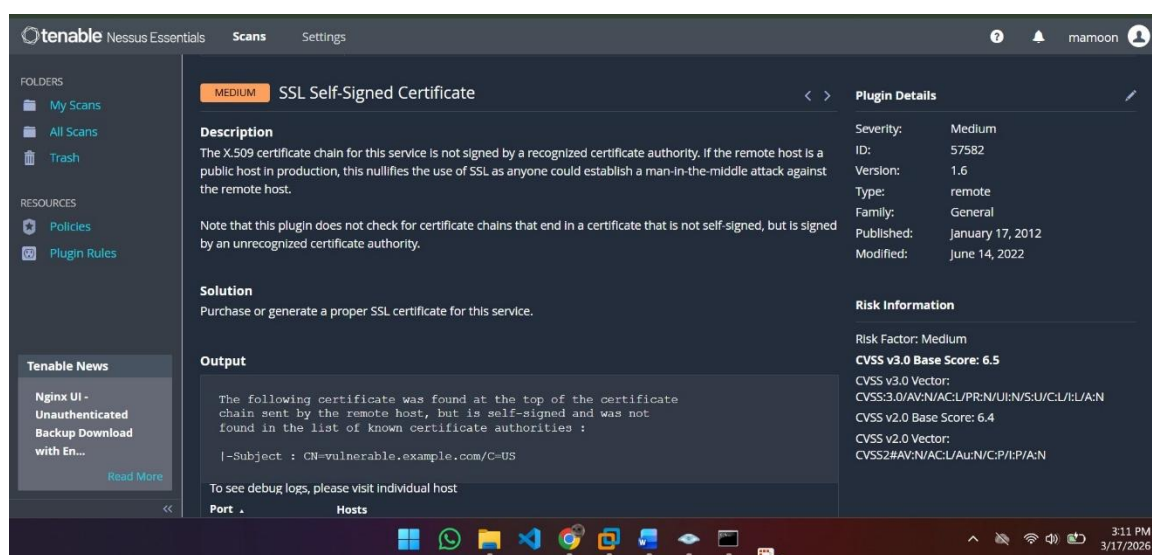
Impact

The FTP service presents a self-signed SSL certificate (CN=vulnerable.example.com) generated with a 512-bit RSA key signed using SHA-1. This combination fails on four levels: (1) the certificate is not trusted by any public CA, (2) the hostname does not match the server IP, (3) the RSA key length is trivially factorable, and (4) SHA-1 is susceptible to collision attacks enabling certificate forgery.

Recommended Solution

Replace the self-signed certificate with one issued by a trusted CA (e.g., Let's Encrypt or an internal PKI). Generate a new RSA key of at least 2048 bits (preferably 4096 bits or ECDSA P-256). Use SHA-256 or stronger for the signature algorithm. Ensure the CN/SAN matches the server's FQDN or IP address.

Evidence / Screenshot



Nessus- SSL Self-Signed Certificate & Wrong Hostname detected (Plugins 57582, 45411)

5.3.4. TLS 1.0 and TLS 1.1 Deprecated Protocols MEDIUM

Host: 192.168.163.136 Port: 21/tcp (FTP-SSL) CVE/Reference: CWE-327 | CVSS v3.0: 6.5 | Nessus Plugins 104743, 157288

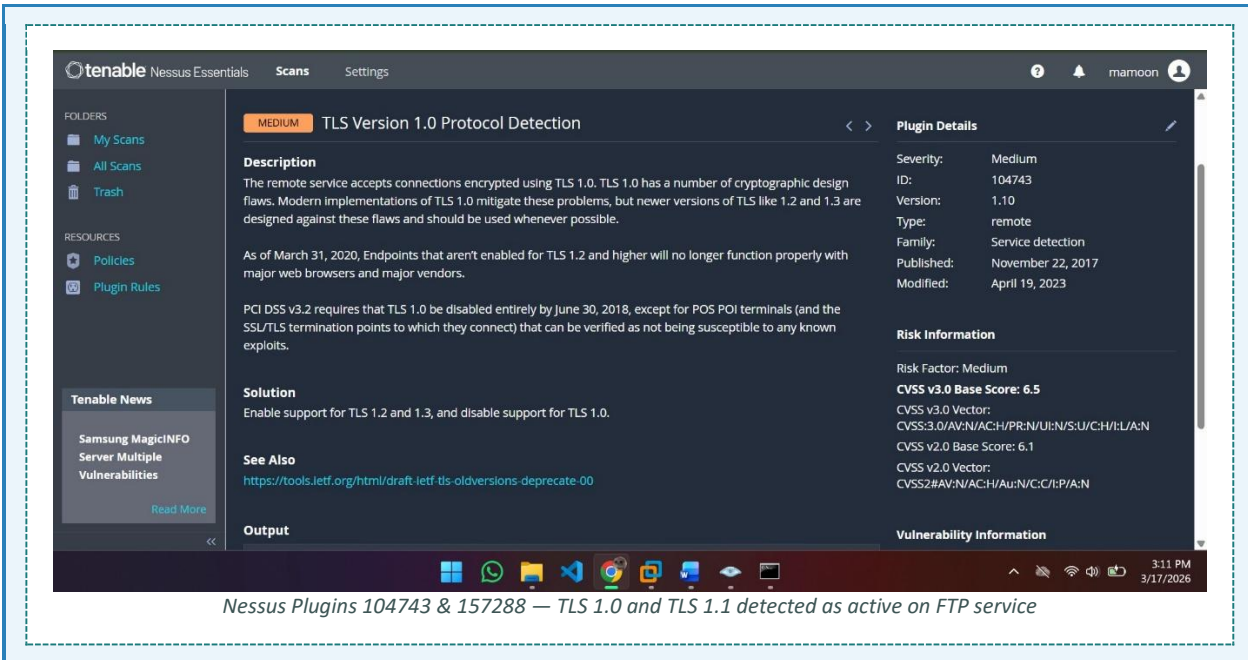
Impact

The service supports TLS 1.0 and TLS 1.1, both of which are deprecated by PCI DSS v3.2, IETF RFC 8996, and major browser vendors. TLS 1.0 is vulnerable to BEAST; TLS 1.1 lacks support for AEAD cipher modes (GCM). These versions can be exploited in downgrade attacks.

Recommended Solution

Disable TLS 1.0 and TLS 1.1 via IIS configuration and Windows SChannel registry keys. Enable TLS 1.2 and TLS 1.3 exclusively. Reference the Microsoft documentation on disabling legacy TLS protocols.

Evidence



5.4 Low Findings

5.4.1. ICMP Timestamp Request Remote Date Disclosure LOW

Host: 192.168.163.136 Port: ICMP (Protocol-level) CVE/Reference: CVE-1999-0524 | Nessus Plugin 10114

Impact

The host responds to ICMP Type 13 (Timestamp Request) packets, disclosing the system time. While low severity in isolation, this information can be used to defeat time-based authentication mechanisms and assist attackers in bypassing Kerberos ticket validity windows.

Recommended Solution

Implement a host-based firewall rule (or Windows Advanced Firewall) to block inbound ICMP Type 13 and outbound ICMP Type 14 packets.

Evidence

Vulnerabilities 36

LOW ICMP Timestamp Request Remote Date Disclosure

Description
The remote host answers to an ICMP timestamp request. This allows an attacker to know the date that is set on the targeted machine, which may assist an unauthenticated, remote attacker in defeating time-based authentication protocols.

Timestamps returned from machines running Windows Vista / 7 / 2008 / 2008 R2 are deliberately incorrect, but usually within 1000 seconds of the actual system time.

Solution
Filter out the ICMP timestamp requests (13), and the outgoing ICMP timestamp replies (14).

Output
The ICMP timestamps seem to be in little endian format (not in network format)
The difference between the local and remote clocks is 3 seconds.

To see debug logs, please visit individual host

Plugin Details

Severity:	Low
ID:	10114
Version:	1.56
Type:	remote
Family:	General
Published:	August 1, 1999
Modified:	October 7, 2024

VPR Key Drivers

- Threat Recency: No recorded events
- Threat Intensity: Very Low
- Exploit Code Maturity: PoC
- Age of Vuln: 730 days +
- Product Coverage: Very High
- CVSSV3 Impact Score: 1.4
- Threat Sources: No recorded events

Nessus Plugin 10114 -ICMP Timestamp Request Remote Date Disclosure

5.4.2. SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam) **LOW**

Host: 192.168.163.136 Port: 21/tcp (FTP-SSL) CVE/Reference: CVE-2015-4000 | Nessus Plugin 83875

Impact

The FTP-SSL service supports Diffie-Hellman key exchange using a modulus of 1024 bits or fewer. Through cryptanalytic techniques (Logjam), a well-resourced attacker may factor the DH modulus and recover session keys, enabling passive decryption of captured traffic.

Recommended Solution

Configure the service to use a custom DH modulus of at least 2048 bits. Generate a fresh DH parameters file using: `openssl dhparam -out dhparam.pem 2048` and bind it to the FTP/SSL service configuration.

Evidence

Vulnerabilities 36

LOW SSL/TLS Diffie-Hellman Modulus ≤ 1024 Bits (Logjam)

Description
The remote host allows SSL/TLS connections with one or more Diffie-Hellman moduli less than or equal to 1024 bits. Through cryptanalysis, a third party may be able to find the shared secret in a short amount of time (depending on modulus size and attacker resources). This may allow an attacker to recover the plaintext or potentially violate the integrity of connections.

Solution
Reconfigure the service to use a unique Diffie-Hellman modulus of 2048 bits or greater.

See Also
<https://weakdh.org/>

Output
Vulnerable connection combinations :
SSL/TLS version : TLSv1.0
Cipher suite : TLS1_KE_DHE_RSA_WITH_AES_256_CBC_SHA

Plugin Details

Severity:	Low
ID:	83875
Version:	1.42
Type:	remote
Family:	Misc.
Published:	May 28, 2015
Modified:	December 15, 2025

VPR Key Drivers

- Threat Recency: No recorded events
- Threat Intensity: Very Low
- Exploit Code Maturity: Unproven
- Age of Vuln: 730 days +
- Product Coverage: Very High
- CVSSV3 Impact Score: 1.4
- Threat Sources: No recorded events

Nessus Plugin 83875 - SSL/TLS DH Modulus ≤ 1024 bits (Logjam) on FTP-SSL

6. RISK SUMMARY & REMEDIATION ROADMAP

The table below prioritizes remediation actions by urgency and expected risk reduction impact.

#	Action Item	Priority	Effort	Expected Outcome
1	Upgrade to Windows Server 2022	Immediate	High	Eliminates all OS-level CVEs; removes unsupported-software risk
2	Disable SSL 2.0, SSL 3.0, TLS 1.0, TLS 1.1	Immediate	Low	Eliminates protocol downgrade and POODLE attack surface
3	Replace weak SSL certificate (512-bit / SHA-1)	Immediate	Low	Removes certificate-based MitM and forgery risks
4	Enforce strong cipher suites only (AES-GCM)	Short-term	Low	Mitigates SWEET32 and RC4 biasing attacks
5	Enable mandatory SMB signing	Short-term	Low	Prevents NTLM relay and SMB MitM attacks
6	Apply MS16-047 and all pending patches	Short-term	Medium	Closes SAM/LSAD privilege escalation pathway
7	Block ICMP Timestamp via firewall	Medium-term	Low	Removes time-based information leakage
8	Generate 2048-bit+ DH parameters	Medium-term	Low	Mitigates Logjam key-recovery risk
9	Establish patch management schedule	Ongoing	Medium	Prevents future exposure to known CVEs
10	Conduct quarterly vulnerability assessments	Ongoing	Medium	Maintains continuous visibility of security posture

7. CONCLUSION

This vulnerability assessment of the Windows Server 2012 R2 lab environment identified 17 findings spanning Critical through Low severity tiers. The assessment demonstrates how a combination of unsupported software, weak cryptographic standards, and misconfigured services can create a compounding attack surface that an adversary could exploit in a systematic manner.

The two Critical findings—an end-of-life operating system and SSL 2.0/3.0 protocol support - represent the most urgent remediation priorities, as each carries a CVSS v3.0 score above 9.5 and enables remote, unauthenticated exploitation paths. The High and Medium findings, predominantly centered on weak SSL/TLS configurations across the FTP service, further amplify the risk by providing additional vectors for man-in-the-middle attacks and credential interception.

Following the structured remediation roadmap presented in Section 6 will substantially reduce the system's attack surface. Immediate actions—OS upgrade, protocol hardening, and certificate replacement—carry low implementation effort relative to their risk-reduction impact. Ongoing practices such as routine vulnerability scanning and patch management are essential to sustaining security posture over time.

This exercise underscores the value of proactive vulnerability assessment as a core component of any security program. Detecting and remediating weaknesses before adversaries can exploit them is far less costly than responding to a breach after the fact.